

Threat Advisory - LSHIY Password Spray: Azure CLI ROPC Attack Bypasses MFA at Scale

Snowbit by Coralogix - Threat Intelligence Advisory

Executive Summary

An automated, large-scale password spray campaign has been actively targeting Microsoft Azure CLI environments since at least June 12, 2026. The threat actor, operating from an IPv6 address range controlled by internet hosting provider LSHIY LLC (AS32167), executed over 81 million login attempts against Microsoft 365 tenants in a 14-day window.

The distinguishing element of this campaign is the abuse of the OAuth 2.0 Resource Owner Password Credentials (ROPC) flow, a deprecated grant type that submits credentials directly to the /token endpoint without triggering an interactive authentication prompt. Because Conditional Access Policies (CAPs) are evaluated at the authorization endpoint, ROPC sign-ins bypass MFA enforcement entirely when policies are not explicitly scoped to cover it. This allowed the actor to compromise accounts at organizations that believed MFA was fully protecting them.

Credential material consists of previously breached username/password pairs that victims had never rotated. Targeting is indiscriminate driven entirely by credential prevalence in leaked combo lists, not industry or company size. Organizations with MFA enabled are not automatically protected. Businesses who were compromised had MFA in place; none were configured to block this attack vector.

How It Works

1. **Credential acquisition:** The actor sources validated username/password pairs from previously breached combo lists. Accounts where credentials were never rotated post-breach are the exclusive target population.
2. **ROPC spray via Azure CLI:** Automated tooling originating from IPv6 range 2a0a:d683::/32 (LSHIY LLC, AS32167) submits credentials directly to the Microsoft Entra ID /token endpoint using the OAuth 2.0 ROPC grant type the same flow used by the Azure CLI for non-interactive authentication.
3. **MFA bypass via protocol gap:** ROPC is non-interactive. It does not redirect through the authorization endpoint where Conditional Access Policies fire. MFA prompts are injected at the authorization stage; ROPC calls to /token skip that stage entirely. Misconfigured CAPs (scoped by app, group, or trusted location) fail to intercept these sign-ins.
4. **Token issuance and account access:** On successful credential validation, Entra ID mints a user-delegated access token. The actor receives a valid session with no MFA challenge granting full access to Exchange Online, Teams, SharePoint, and OneDrive for the compromised account.

ROPC sign-ins appear in Entra ID as NonInteractiveUser events. The key MFA misconfigurations observed across compromised organizations:

- MFA gap 1: Enforced for specific apps only (e.g., Admin Portals) Azure CLI excluded
- MFA gap 2: Scoped to specific groups (e.g., Admins) standard user accounts exposed
- MFA gap 3: Trusted-location exclusions attacker IPs mislabeled as US by geolocation
- MFA gap 4: Report-only mode policy logging enabled but never enforced

Timeline

Date & Time (UTC)	Event
2021-06-14	LSHIY LLC registers AS32167
2022-06-22	LSHIY LLC registers AS955 (secondary ASN)
2026-06-11	IPv6 range maintainer entry created for 2a0a:d683::/32 (per RIPE records)
2026-06-12	Earliest confirmed campaign activity; 2-4 account compromises per day
2026-06-19	Single-day spike: 12 user accounts compromised
2026-06-22	Major surge: 30 accounts compromised across 23 businesses in one day
2026-06-12 – 2026-06-26	Campaign window: 81M+ login attempts

Key Affected Packages

This is an identity/authentication attack no software packages are malicious. The table below describes the affected Microsoft components and the configuration states that create exposure.

Affected Component	Vulnerable Configuration	Protected Configuration
Microsoft Entra ID / Azure AD	ROPC not blocked by CAP; MFA scoped to apps/groups/locations only	CAP with userStrongAuthClientAuthNRequired enforced for All Users, All Cloud Apps
Azure CLI	All versions ROPC is a protocol-level auth flow, not a CLI bug	Restrict Azure CLI to admin accounts; block for standard users via CAP
Conditional Access Policies	Policies missing All Client App types coverage; report-only mode	All Users / All Cloud Apps / All Client App Types, enforced

Remediation

If you suspect accounts in your environment have been compromised, follow these steps immediately:

- **Audit Conditional Access Policies:** Verify at least one policy enforces MFA (or block) for All Users, All Cloud Apps, and All Client App Types. Any scope exclusion app, group, or location creates an attack surface for ROPC.
- **Enable userStrongAuthClientAuthNRequired:** Apply this CAP setting to enforce strong authentication at the client level. It causes ROPC-based flows to fail before token issuance, blocking this attack class entirely.
- **Block 'Other clients' client app type:** Create a CAP targeting the 'Other clients' app type for non-admin users. If Azure CLI is required for admin workflows, create a separate scoped policy restricting it to privileged accounts.
- **Force password resets for breached accounts:** Cross-reference user credentials against breach databases (Microsoft Entra ID Protection leaked credentials signals, HIBP Enterprise API). Reset any account appearing in breach datasets immediately.
- **Review Non-Interactive sign-in logs:** In Entra ID / your SIEM, query NonInteractiveUserSignInLogs for clientAppUsed = 'Other clients' or authenticationProtocol = 'ropc' from IPv6 ranges. Look for resultType = 0 (success) with no MFA claim.
- **Block LSHIY IPv6 range:** Block 2a0a:d683::/32 at firewall/proxy/CAP network location level. Note: geolocation of these IPs is inconsistent (resolves to both China and US Nebraska) and do not rely on location-only controls.
- **Deploy phishing-resistant MFA:** FIDO2 passkeys and certificate-based auth are immune to credential stuffing; the credential is never shared with the identity provider. Migrate high-value accounts as priority.

Indicators of Compromise

Type	Indicators
Source IPv6 Range	2a0a:d683::/32
ASN	AS32167 (LSHIY LLC, primary) · AS955 (LSHIY LLC, secondary)
Infrastructure Owner	LSHIY LLC addresses in Hong Kong, Wuhan (China), 42 Broadway NY (shared office)
Auth Protocol	OAuth 2.0 ROPC flow to /token endpoint (clientAppUsed: Other clients)
Sign-in Log Signal	authenticationProtocol: ropc · isInteractive: false · resultType: 0 (success)
MFA Signal	authenticationRequirement: singleFactorAuthentication · no mfa in amr claim
Credential Source	Previously breached username/password combo lists (unrotated credentials)

DataPrime Hunting Queries

8.1 Detect ROPC Sign-ins from LSHIY ASNs (AS32167 + AS955)

```
source logs
| filter $d.properties.authenticationProtocol:string == 'ropc'
| filter $d.cx_security.source_ip_geoip.asn.number ~ '32167'
|   || $d.cx_security.source_ip_geoip.asn.number ~ '955'
| choose $m.timestamp, $d.properties.userName, $d.callerIpAddress,
  $d.resultType:string, $d.cx_security.source_ip, $l.applicationname
| orderby $m.timestamp desc | limit 200
```

Identifies all ROPC sign-in events originating from LSHIY LLC ASNs. resultType '0' = success (immediate triage priority); non-zero = failed spray attempt.

8.2 Detect Successful Single-Factor Auth from LSHIY ASNs

```
source logs
| filter $d.resultType:string == '0'
| filter $d.properties.authenticationRequirement:string == 'singleFactorAuthentication'
| filter $d.cx_security.source_ip_geoip.asn.number ~ '32167'
|   || $d.cx_security.source_ip_geoip.asn.number ~ '955'
| choose $m.timestamp, $d.properties.userName, $d.callerIpAddress,
  $d.properties.appDisplayName, $d.cx_security.source_ip
| orderby $m.timestamp desc | limit 100
```

Finds successful password-only authentications from both LSHIY ASNs; these are confirmed compromised accounts requiring immediate response.

8.3 Tenant-Wide ROPC Spray Volume by Account

```
source logs
| filter $d.properties.authenticationProtocol:string == 'ropc'
| groupby $d.properties.userName, $d.callerIpAddress as attempts count()
| filter attempts > 5
| orderby attempts desc | limit 100
```

Surfaces all spray-targeted accounts across the tenant regardless of ASN useful for detecting campaign activity from infrastructure not yet attributed to LSHIY.

8.4 Hourly Spray Spike Detection (Last 30 Days)

```
source logs
| filter $d.properties.authenticationProtocol:string == 'ropc'
| filter $d.resultType:string != '0'
| timechart count() by $d.properties.userName span 1h
| filter count > 100
```

ROPC attempts per user per hour. Spikes above 100/hour per account indicate active spray targeting. Tune threshold based on tenant baseline.

Snowbit Response

- **Immediate IOC enrichment:** The LSHIY IPv6 range 2a0a:d683::/32 and associated ASNs (AS32167, AS955) have been ingested into the Snowbit threat intelligence platform.
- **Customer environment scanning:** Snowbit has initiated proactive sweeps across customer Coralogix environments for ROPC sign-in events, successful single-factor authentications from IPv6 ranges, and NonInteractiveUser log entries with missing MFA claims.
- **Advisory distribution:** This advisory has been distributed to all Snowbit managed customers via the threat intelligence notification channel. Customers are advised to complete the CAP audit in Remediation within 24 hours.

We strongly recommend all customers immediately audit their Conditional Access Policies to ensure MFA is enforced for All Users, All Cloud Apps, and All Client App Types with no trusted-location or group exclusions that could expose the OAuth ROPC flow.